
SESIÓN 6 DE 6 · 5 HORAS · BLOQUE 11: 2H15 · DESCANSO 30 MIN · BLOQUE 12: 2H15

GESTIÓN DE LLAVES Y LO QUE VIENE

LA LLAVE ES UN ACTIVO. TIENE DUEÑO, TIENE FECHA Y TIENE SUCESOR.

SIO0010 · Técnicas Criptográficas · Especialización en Seguridad de la Información de las Organizaciones · Facultad de Ingeniería · Institución Universitaria de Envigado

SECCIÓN

01

EL CIERRE DEL MÓDULO

Lo que falta para que las cinco sesiones anteriores se sostengan en el tiempo

AGENDA DE LA SESIÓN

La última sesión tiene tres partes: la gestión de las llaves, que es lo que hace durable todo lo anterior; lo que viene después de la criptografía actual; y la sustentación ante el comité.

BLOQUE	MINUTOS	CONTENIDO	MODALIDAD
Bloque 11	0 – 10	Recepción de la entrega 5	Taller
	10 – 75	La llave como activo: NIST SP 800-57, ceremonias, módulos de hardware y tokenización	Magistral
	75 – 105	Laboratorio 6, en Python	Laboratorio
	105 – 135	Conservación a veinte años y cierre del hallazgo H7	Magistral
Descanso	30		
Bloque 12	0 – 40	Transición post-cuántica: CNSA 2.0, NIST IR 8547 y criptoagilidad	Magistral
	40 – 55	Quiz 2 · Sesiones 4, 5 y 6	Evaluación
	55 – 125	Sustentación de la hoja de ruta ante el comité	Sustentación
	125 – 135	Cierre del módulo	Magistral

LAS SEIS SESIONES, EN UNA SOLA FRASE CADA UNA

Antes de la última pieza conviene ver el hilo completo. Cada sesión respondió una pregunta y dejó una abierta, y la siguiente la recogió.

SESIÓN	LO QUE RESOLVIÓ	LO QUE DEJÓ ABIERTO
1 · Panorama	Qué servicios presta la criptografía y por qué hay que inventar	No sabemos proteger el dato guardado
2 · Simétrico	Cifrar volúmenes, y por qué el modo importa más que el algoritmo	Una llave compartida no prueba quién hizo qué
3 · Resúmenes	Integridad, contraseñas y autenticación de mensajes	Un código con llave compartida no da no repudio
4 · Llave pública	Firma digital: el único mecanismo con no repudio	¿De quién es esa llave pública?
5 · Certificados	Cadena de confianza, canal seguro y ciclo del certificado	¿Quién custodia las llaves, y por cuánto tiempo?
6 · Hoy	Gestión de llaves, conservación y transición	Nada: es la sustentación

RECEPCIÓN DE LA ENTREGA 5

Diez minutos. Se recibe el análisis del valor probatorio de los créditos y se revisan dos puntos que conviene tener claros antes de la sustentación.

// LA DECISIÓN QUE NO SE PUEDE ESQUIVAR

Hay cartera vigente firmada con una imagen escaneada. Ninguna solución técnica la arregla hacia atrás.

Las tres salidas posibles son: resellar lo que se pueda, aceptar el riesgo documentándolo, o provisionarlo contablemente.

Un informe que no elige una no está terminado, y en la sustentación el comité va a preguntar por ella.

// EL COSTO POR DOCUMENTO

Los equipos que cotizaron descubrieron que el costo no está en la firma: está en la conservación año tras año.

Firmar es un gasto único; conservar con validez comprobable durante veinte años es un gasto recurrente.

Ese cambio de mentalidad, de compra a servicio, es lo que hay que llevarle al comité.

SECCIÓN

02

LA LLAVE COMO ACTIVO

Generación, custodia, rotación y retiro: el oficio que Coopaburrá no hizo

LAS SIETE ETAPAS DE LA VIDA DE UNA LLAVE

Ninguna de estas etapas es criptográfica. Todas son de gestión, y es en ellas donde fallan los sistemas reales, incluido el de este caso.

ETAPA	QUÉ HAY QUE DEFINIR	QUÉ PASA SI NO SE DEFINE
Generación	Dónde se genera y con qué fuente de aleatoriedad	Llaves predecibles, y no se sabe hasta que es tarde
Registro	Identificador, propósito, responsable y fecha de vencimiento	El hallazgo H8: nadie sabe qué llaves existen
Distribución	Cómo llega a donde se usa sin exponerse	La llave del respaldo en un archivo de texto al lado
Uso	Una llave, un propósito. Y quién puede invocarla	Una sola llave para 142.000 asociados desde 2023
Rotación	Cada cuánto y con qué procedimiento sin cortar el servicio	Las llaves de los 32 cajeros: siete años sin rotar
Retiro	Cuándo deja de usarse para proteger, pero sigue guardada para descifrar lo viejo	Datos antiguos que ya nadie puede leer
Destrucción	Cuándo se borra de verdad, y con qué constancia	Se borra una llave que todavía protegía datos vivos

DE DÓNDE SALE LA ALEATORIEDAD

Es la tercera vez en el módulo que la aleatoriedad decide todo, y vale la pena cerrar el tema con los dos casos donde de verdad falla en producción.

// EL ARRANQUE EN FRÍO

Un servidor recién encendido, o una máquina virtual recién creada, todavía no ha acumulado suficiente entropía.

Las llaves generadas en ese primer instante pueden ser predecibles.

Se han encontrado en internet miles de llaves de servidores que compartían factores, justamente por esto.

// LOS EQUIPOS EMBEBIDOS

Un cajero, un lector de tarjetas o un dispositivo industrial no tienen teclado, ni ratón, ni disco con actividad variada.

Sin una fuente de hardware dedicada, su aleatoriedad es pobre y repetible entre equipos del mismo lote.

Para los 32 cajeros, esta pregunta es obligatoria: ¿dónde se generaron esas llaves y con qué fuente?

LA CEREMONIA DE LLAVES

Una ceremonia es un procedimiento documentado para generar o cargar una llave crítica de forma que nadie, individualmente, la conozca ni pueda usarla. Suena solemne y es, sobre todo, un acta.

01 Custodios nombrados, con suplentes y con acta

Personas identificadas por rol, no por nombre propio, para que la salida de alguien no deje la llave huérfana. Es exactamente lo que le pasó a Coopaburrá.

02 Doble control y conocimiento dividido

Doble control: hacen falta al menos dos personas para ejecutar la operación. Conocimiento dividido: ninguna de ellas conoce la llave completa.

03 Guion previo, testigos y registro de cada paso

Se escribe antes lo que se va a hacer, se ejecuta con testigos y se firma el acta al terminar, con las huellas de verificación.

04 Resguardo de las partes en custodias separadas

Sobres o dispositivos sellados, en cajas fuertes distintas, con control de apertura. Reunir las partes exige reunir a las personas.

REPARTIR UN SECRETO ENTRE VARIAS PERSONAS

El conocimiento dividido tiene una solución matemática elegante que conviene conocer, porque aparece en toda documentación de módulos de hardware.

UMBRAL k DE n

Un secreto se puede partir en n partes de modo que hagan falta k de ellas para reconstruirlo, y que con $k-1$ no se sepa absolutamente nada.

Ejemplo típico: 5 custodios, se necesitan 3 para reconstruir.

Tolera que dos custodios no estén disponibles.

Resiste que dos custodios se pongan de acuerdo para robarla.

No es partir la llave en pedazos: con $k-1$ partes no hay ninguna ventaja, ni siquiera parcial. Esa es la diferencia con cortar un papel en cinco.

POR QUÉ NO SE CIFRA TODO CON LA MISMA LLAVE

La forma estándar de organizar llaves en una entidad es en niveles, y entenderla resuelve la pregunta práctica de cómo se rota sin descifrar y volver a cifrar toda la base.

TRES NIVELES

LLAVE MAESTRA	en módulo de hardware, ceremonia, nunca sale
protege	
LLAVE DE LLAVES	cifra las llaves de datos; rota anualmente
protege	
LLAVES DE DATOS	una por campo, por archivo o por cliente

Rotar la llave de llaves = volver a cifrar unas pocas llaves pequeñas.

Rotar la llave maestra = ceremonia, pero no toca ni un solo dato.

Sin jerarquía, rotar significa descifrar y recifrar 142.000 registros.

// LA RESPUESTA A LA OBJECCIÓN MÁS FRECUENTE

Cuando alguien diga que rotar llaves es inviable porque habría que recifrarlo todo, la respuesta es esta diapositiva: **con una jerarquía de llaves, rotar es barato**. Lo inviable es no haberla diseñado.

CADA CUÁNTO SE ROTA Y CÓMO

TIPO DE LLAVE	PERIODO SEGÚN SP 800-57	CÓMO SE ROTA SIN CORTAR EL SERVICIO
Llave de sesión	Cada conexión	Automático: es lo que hace el canal seguro
Llave de datos	Hasta dos años para cifrar, o ante incidente	Se cifra lo nuevo con la llave nueva y se conserva la vieja para leer lo anterior
Llave de llaves	Hasta dos años; anual es buena práctica	Se recifran solo las llaves de datos: minutos, no días
Llave raíz del módulo de hardware	Hasta dos años, como toda llave que cifra llaves	Ceremonia. No se toca ni un solo dato
Llaves de dispositivos	Lo que diga el fabricante. Aquí, dos años	Por lotes, con ventana de mantenimiento. Los 32 cajeros llevan siete años
Pareja de firma de una persona	La vigencia del certificado	Se emite una nueva; las firmas antiguas siguen siendo válidas si hay sello de tiempo

LOS PERIODOS CRIPTOGRÁFICOS DE NIST SP 800-57

La norma de referencia para el ciclo de vida de las llaves. Su tabla de periodos criptográficos es lo que cualquier auditor espera ver citado en una política de llaves.

TIPO DE LLAVE	USO PARA PROTEGER	USO PARA LEER O VERIFICAR
Simétrica de cifrado de datos	Hasta 2 años	Hasta 3 años más, solo para descifrar
Simétrica que cifra otras llaves	Hasta 2 años	Hasta 3 años más
Simétrica de autenticación · la de H2	Hasta 2 años	Hasta 3 años más. La de Coopaburrá lleva tres sin rotar
Privada de firma	1 a 3 años	La pública verifica por más tiempo, según su tamaño
Maestra simétrica de derivación	Alrededor de 1 año	—
Efímera de acuerdo de llave	Una sola transacción	—

// LOS DOS PERIODOS DE UNA MISMA LLAVE

Una llave de datos deja de cifrar a los dos años, pero se conserva para descifrar lo ya cifrado. **Rotar no es borrar.**

LOS SEIS ESTADOS DE UNA LLAVE

SP 800-57 define seis estados y las transiciones permitidas entre ellos. Registrar el estado de cada llave es lo que convierte el inventario en un instrumento de gestión.

ESTADO	QUÉ SE PUEDE HACER CON LA LLAVE	EJEMPLO EN EL CASO
Pre-activación	Nada todavía: existe, pero su uso no está autorizado	La llave nueva de los cajeros, generada y aún sin cargar
Activa	Cifrar y firmar, y también descifrar y verificar	La llave del respaldo, hoy
Suspendida	Nada, temporalmente, mientras se investiga	Un teléfono reportado como perdido, mientras se confirma
Desactivada	Solo descifrar o verificar lo que ya existía	La llave de datos rotada, que se guarda para leer lo viejo
Comprometida	Solo lo necesario para gestionar el incidente	La raíz interna de 2019, según la conclusión de la sesión 5
Destruída	Nada: ya no existe, y queda constancia	Lo que nunca debe pasarle a una llave que aún protege datos vivos

EL HALLAZGO H6, LEÍDO CON TODO LO ANTERIOR

LO QUE DICE EL HALLAZGO

QUÉ ETAPA DEL CICLO FALTÓ

Se cargaron manualmente en la puesta en marcha, en 2019

Generación y distribución: no consta dónde se generaron ni con qué fuente

Lo ejecutaron dos personas, una ya no trabaja allí

Custodia: había dos personas, pero no custodios por rol ni suplentes

No hay registro de ceremonia

Registro: sin acta no se puede probar quién conoció la llave, ni descartar una copia

Ni custodios designados, ni doble control

Uso: una sola persona pudo haber operado la llave completa

Ni fecha de rotación. El fabricante recomienda dos años; van siete

Rotación: el procedimiento no existe, así que la fecha nunca llegó

// LO QUE HAY QUE ESCRIBIR EN EL INFORME

El hallazgo no es que las llaves sean débiles: **puede que sean perfectamente fuertes**. El hallazgo es que no existe forma de afirmar quién las conoce. Y con 32 cajeros propios, eso es una exposición que la Superintendencia va a preguntar.

UNA LLAVE SIN DUEÑO, SIN FECHA Y SIN ACTA NO ES UN CONTROL: ES UNA DEUDA.

Los cinco hallazgos de gestión de este caso — la llave del código, la del respaldo, la de la autoridad interna, las de los cajeros y la ausencia de inventario — tienen la misma forma. En todos, el algoritmo era correcto y lo que faltaba era alguien que respondiera por la llave, una fecha en la que dejara de valer y un documento que probara quién la conoció. Eso no se compra: se gobierna. Y es exactamente lo que el comité les está pidiendo.

MÓDULOS DE HARDWARE: QUÉ SE COMPRA REALMENTE

Cuando alguien propone comprar un módulo de hardware, lo que hay que preguntar no es la marca: es el nivel certificado, porque de ahí depende si sirve para lo que se quiere.

NIVEL	QUÉ GARANTIZA	PARA QUÉ ALCANZA
Nivel 1	Requisitos criptográficos básicos. Puede ser puro software	Cumplimiento formal. No protege la llave de quien administre el equipo
Nivel 2	Evidencia física de manipulación y autenticación por rol	Entornos controlados con vigilancia física
Nivel 3	Resistencia física activa: ante intrusión, borra las llaves. Autenticación por identidad	Es el nivel habitual del sector financiero, y el que aplica a este caso
Nivel 4	Protección total, incluida la detección de ataques por temperatura o voltaje	Entornos hostiles o de altísima exigencia. Rara vez necesario

// LA PREGUNTA QUE DESARMA UNA PROPUESTA COMERCIAL

¿La llave se genera dentro del módulo y no puede salir nunca, o se genera fuera y se importa? **Si puede salir, el módulo es un lugar cómodo donde guardarla, no una garantía de custodia exclusiva.**

CUSTODIA DE LLAVES EN LA NUBE

Casi ninguna organización monta hoy su propio módulo: lo alquila. Eso está bien, y cambia las preguntas que hay que hacer, no la responsabilidad.

MODELO	QUIÉN CONTROLA LA LLAVE	CUÁNDO CONVIENE
Llaves administradas por el proveedor	El proveedor, por completo. El cliente solo elige activarlo	Datos de sensibilidad baja o media, cuando lo que se busca es no tener que operar nada
Llaves del cliente dentro del servicio	El cliente define políticas, permisos y rotación; el proveedor opera el módulo	El punto de equilibrio habitual, y el razonable para Coopaburrá
Llave propia importada	El cliente la genera en su propia ceremonia y la importa	Quando hay que poder demostrar el origen de la llave ante un supervisor
Módulo externo bajo control propio	El cliente, incluso frente al proveedor de nube	Datos que no pueden quedar accesibles al proveedor por requisito legal o contractual

// LAS CUATRO PREGUNTAS PARA EL CONTRATO

¿En qué país reside la llave? ¿Puede el proveedor acceder a ella, y bajo qué orden judicial? ¿Qué registro de uso queda y quién lo audita? ¿Y qué pasa con las llaves el día que se termine el contrato? **Delegar la operación no delega la responsabilidad ante la Superintendencia.**

TOKENIZACIÓN: SUSTITUIR EN VEZ DE CIFRAR

La técnica que más reduce el riesgo cuando el dato no se necesita en claro para operar. En lugar de cifrarlo, se reemplaza por un sustituto que no tiene ninguna relación matemática con él.

TOKENIZACIÓN CON BÓVEDA

Número de tarjeta: 4000 1234 5678 9010

Token: 4000 1293 8841 9010 ← mismo formato, sin relación con el original

La correspondencia entre token y dato real vive en una bóveda, separada y custodiada.

Los demás sistemas solo ven el token: pueden operar, conciliar y reportar sin haber tenido nunca el dato real.

// DOS VARIANTES

Con bóveda: una tabla protegida guarda la correspondencia. Sin bóveda: el token se calcula con un cifrado que conserva el formato, como el FF1 de la NIST SP 800-38G. **La primera es más simple de razonar; la segunda escala mejor**, y exige custodiar una llave.

TOKENIZACIÓN FRENTE A CIFRADO

No compiten: resuelven problemas distintos. La pregunta que decide es si el sistema necesita el dato real para hacer su trabajo.

CRITERIO	CIFRADO	TOKENIZACIÓN
Relación con el dato	Matemática: con la llave se recupera	Ninguna: solo la bóveda conoce la correspondencia
Formato	El resultado es otro tipo de dato, más largo	Puede conservar el formato: los sistemas no cambian
Si se roba lo protegido	A salvo mientras la llave lo esté	El token no sirve de nada fuera del sistema
Qué hay que custodiar	La llave	La bóveda, o la llave si es sin bóveda
Alcance de auditoría	Todo sistema que tenga la llave	Solo la bóveda y lo que la consulta: el resto sale del alcance
Mejor para	Datos que se usan en claro con frecuencia	Identificadores que se guardan y se comparan, pero casi nunca se leen

TOKENIZACIÓN EN COOPABURRÁ

Tres datos del caso donde la tokenización resuelve mejor que el cifrado, y uno donde no tiene sentido.

DATO	¿QUIÉN LO NECESITA EN CLARO?	RECOMENDACIÓN
Número de tarjeta de los asociados	Solo el autorizador de transacciones	Tokenizar: saca de la norma de tarjetas a todos los demás sistemas
Cédula en analítica y en archivos para terceros	Nadie: basta un identificador estable	Tokenizar. Resumirla no sirve: se revierte, como en la sesión 3
Cédula en el core	Varios procesos, todos los días	Cifrado de campo con índice ciego, como en la sesión 2
Saldo	La operación completa, todo el tiempo	Cifrado de campo y control de acceso; tokenizarlo no tiene sentido

// EL ARGUMENTO ANTE EL COMITÉ

Tokenizar la tarjeta **reduce el número de sistemas que audita la norma de tarjetas**, y con eso su costo anual. Es de las pocas medidas de seguridad que se pueden presentar como ahorro.

LA LLAVE DEL RESPALDO, VISTA DESDE LA GESTIÓN

El hallazgo H4 lo diagnosticaron en la sesión 2. Ahora ya se puede decir dónde debería estar esa llave y por qué, que es lo que el informe necesita.

// POR QUÉ ESTÁ DONDE ESTÁ

Porque el guion de respaldo debe ejecutarse solo, de madrugada, sin intervención humana.

Es una necesidad operativa real, y por eso la solución no puede ser simplemente quitar el archivo.

Quien lo diseñó no fue negligente: resolvió el problema que tenía delante sin el marco que ustedes ya tienen.

// DÓNDE DEBERÍA ESTAR

En un servicio de gestión de llaves, al que el proceso de respaldo se autentica **como proceso**, con permiso solo para cifrar.

Y con una llave distinta para descifrar, cuyo uso exija aprobación de una persona y quede registrado.

Así, quien tenga el archivo de respaldo no puede leerlo, y quien pueda leerlo no tiene el archivo. Eso es separación de funciones.

QUÉ SE HACE CUANDO UNA LLAVE SE COMPROMETE

Rotar por calendario es rutina. Rotar por incidente es otra cosa, y conviene tener el procedimiento escrito antes de necesitarlo.

01 Declarar, revocar y reemplazar

En ese orden y sin improvisar. Revocar el certificado asociado, emitir la llave nueva y distribuirla por el procedimiento previsto.

02 Determinar el alcance: qué protegió esa llave y durante cuánto tiempo

Sin inventario este paso es imposible, y es el que decide todo lo demás. Es la razón práctica por la que H8 va primero.

03 Reclasificar lo protegido

Lo cifrado con esa llave se considera expuesto. Lo firmado en el periodo se considera dudoso, salvo que haya sello de tiempo que acote la ventana.

04 Preservar evidencia y notificar

El equipo comprometido no se formatea: se preserva. Y hay obligaciones de notificación a titulares y al supervisor que no las decide el área técnica.

SECCIÓN

03

LABORATORIO 6

Treinta minutos · Repartir un secreto, rotar sin recifrar y tokenizar, en Python

LOS TRES EJERCICIOS

01 Ejercicio 1 · Repartir la llave de los cajeros entre cinco custodios

Con un umbral de tres, repartan una llave de 128 bits, reconstrúyanla con tres partes y comprueben que con dos no se obtiene nada.

02 Ejercicio 2 · Rotar la llave maestra sin tocar los datos

Cifren mil registros en sobre, roten la llave que cifra las llaves y verifiquen que todos siguen legibles. Midan cuánto tardó frente a recifrarlo todo.

03 Ejercicio 3 · Tokenizar las cédulas de un archivo de analítica

Reemplacen cada cédula por un token aleatorio, guarden la correspondencia aparte y expliquen qué puede hacer un tercero con el archivo y qué no.

// LO QUE SE ENTREGA

Una página por equipo con los tres resultados y, sobre todo, **la respuesta del ejercicio 3**: va directo a la recomendación de la entrega final.

LABORATORIO 6 - EL EJERCICIO EN PYTHON

Los tres ejercicios con la biblioteca estándar, cryptography y pycryptodome, que trae una implementación del reparto de Shamir.

```
LABORATORIO 6 · PYTHON 3 + CRYPTOGRAPHY + PYCRYPTODOME
```

```
# pip install cryptography pycryptodome
import os, secrets
from Crypto.Protocol.SecretSharing import Shamir
from cryptography.hazmat.primitives.keywrap import aes_key_wrap, aes_key_unwrap
llave_cajeros = os.urandom(16)
partes = Shamir.split(3, 5, llave_cajeros)          # cinco custodios, umbral de tres
assert Shamir.combine(partes[:3]) == llave_cajeros  # tres partes bastan
kek_vieja, kek_nueva = os.urandom(32), os.urandom(32)
dek_envuelta = aes_key_wrap(kek_vieja, os.urandom(32))
dek_rotada = aes_key_wrap(kek_nueva, aes_key_unwrap(kek_vieja, dek_envuelta))
token = secrets.token_hex(8)                       # sustituto sin relación con la cédula
```

// LA PREGUNTA DEL EJERCICIO 2

¿Qué cambió en la base al rotar la llave maestra? Solo las llaves envueltas, de 40 bytes cada una. **Esa es la respuesta a quien diga que rotar llaves es inviable.**

SECCIÓN

04

VEINTE AÑOS

Cómo se conserva una prueba electrónica más tiempo del que dura su tecnología

LA FIRMA TAMBIÉN ENVEJECE

Una firma digital perfectamente válida hoy puede ser imposible de verificar en quince años, sin que nadie haya hecho nada malo. Esta es la parte del hallazgo H7 que no se resuelve firmando.

QUÉ CADUCA	POR QUÉ	QUÉ PASA SI NO SE PREVÉ
El certificado del firmante	Vence en pocos años, o se revoca antes	No se puede comprobar que la llave era suya en el momento de firmar
El algoritmo	SHA-1 era aceptable en 2005 y dejó de serlo. RSA 2048 tiene fecha	La firma deja de constituir prueba, aunque el archivo esté intacto
La información de verificación	Las listas de revocación y las respuestas en línea no se guardan para siempre	No hay forma de reconstruir el estado del certificado en aquella fecha
El formato y el soporte	Veinte años son varias generaciones de software y de medios	El archivo existe y nadie puede abrirlo

SELLO DE TIEMPO: QUÉ ES Y QUÉ PRUEBA

Es la pieza que quedó pendiente desde la sesión 4, y la que convierte una firma en una prueba fechada por alguien distinto de la parte interesada.

SELLADO CRONOLÓGICO

1. Se calcula el resumen del documento ya firmado.
2. Se envía ese resumen – no el documento – a una autoridad de sellado.
3. La autoridad le añade su fuente de tiempo y firma el conjunto.

Resultado: una afirmación firmada por un tercero que dice
"este documento existía exactamente así, en este instante".

La autoridad nunca ve el contenido: solo el resumen. La confidencialidad del expediente se conserva intacta.

// LO QUE ESTO RESUELVE EN EL CASO

Sin sello, la fecha de la hipoteca la pone el reloj de un servidor de la cooperativa, que es parte interesada. **Con sello, la fecha la certifica un tercero**, y además queda probado que la firma se hizo cuando el certificado todavía estaba vigente.

CÓMO SE CONSERVA UNA FIRMA VEINTE AÑOS

Existen formatos de firma diseñados exactamente para esto. La idea es sencilla y conviene explicarla así en el informe, sin nombres de norma.

- 01 Se guarda todo lo necesario para verificar, junto con el documento**
La cadena de certificados completa y el estado de revocación de ese día. Así no hay que consultar nada en el futuro.
- 02 Se sella el conjunto con un sello de tiempo**
El sello cubre el documento, la firma y la evidencia de verificación. Congela el estado completo en una fecha.
- 03 Antes de que el sello envejezca, se vuelve a sellar por encima**
Con algoritmos vigentes en ese momento. Cada sello nuevo protege a todos los anteriores, como capas.
- 04 Se repite indefinidamente, cada pocos años**
Mientras se mantenga la cadena de sellos, la firma original sigue siendo verificable aunque su algoritmo ya no se use.

// POR QUÉ ES UN SERVICIO Y NO UNA COMPRA

El resellado es una tarea periódica que alguien tiene que ejecutar durante dos décadas. **Si no hay un responsable y un presupuesto anual, el esquema se rompe solo en el tercer año**, y nadie se entera hasta el día del litigio.

LOS NIVELES DE FIRMA PARA CONSERVAR: B, T, LT Y LTA

Los cuatro pasos de la diapositiva anterior tienen nombre en las normas europeas de firma avanzada, que son las que implementan los proveedores y las que hay que exigir en el contrato.

NIVEL	QUÉ AGREGA	QUÉ RESUELVE
B · básico	La firma con su certificado	Integridad y autoría, mientras el certificado esté vigente
T · con tiempo	Un sello de tiempo de un tercero	La prueba de cuándo se firmó
LT · largo plazo	La cadena y el estado de revocación, dentro del documento	Verificar sin depender de servicios que ya no existan
LTA · archivo	Sellos de archivo sucesivos sobre todo lo anterior	Mantener la prueba cuando el algoritmo original envejezca

// QUÉ PEDIR EN EL CONTRATO

Para los pagarés de Coopaburrá: firma en PDF con nivel LTA, que en la norma se llama PAdES, **y el servicio de resellado periódico incluido**, con su costo anual. Pedir solo «firma digital» deja por fuera tres cuartas partes del problema.

EL HALLAZGO H7, CERRADO

Con esto ya está completa la respuesta que el comité pedía en febrero. Así se ve el esquema propuesto, de principio a fin.

PIEZA

QUÉ APORTA AL EXPEDIENTE

Firma digital con certificado de entidad acreditada

Atribución al titular, con la presunción legal que la firma electrónica genérica no tiene

Llave privada del asociado bajo su control exclusivo

Es el requisito que convierte la firma en confiable. Sin él, lo demás no sostiene

Sello de tiempo de un tercero

Fecha cierta, independiente del reloj de la cooperativa

Evidencia de verificación guardada con el documento

Permite verificar dentro de veinte años sin consultar servicios que ya no existirán

Resellado periódico

Mantiene la verificabilidad cuando el algoritmo original envejezca

Custodia con integridad demostrable

El registro encadenado de la sesión 3, para que la parte interesada no sea la única fuente

Y LO QUE YA SE FIRMÓ CON UNA IMAGEN

Lo anterior sirve de aquí en adelante. Para la cartera vigente no hay solución técnica completa, y por eso es una decisión del comité y no del área de tecnología.

OPCIÓN	QUÉ LOGRA	QUÉ NO LOGRA
Sellar hoy los documentos existentes	Prueba que el documento existía así desde hoy, y congela cualquier alteración futura	No prueba nada sobre lo ocurrido antes de hoy, que es justo lo discutible
Volver a firmar con el asociado	Expediente completo y sólido	Costo y fricción comercial enormes. Y muchos asociados no van a volver a firmar
Documentar el riesgo y provisionarlo	Es honesto, es defendible ante la Superintendencia y tiene un número asociado	No mejora la posición probatoria en un litigio concreto

// LA RECOMENDACIÓN QUE SE ESPERA DE UN ESPECIALISTA

Las tres a la vez, priorizadas: sellar ya lo existente porque es barato y detiene el deterioro, volver a firmar solo la cartera de mayor exposición, y provisionar el resto.
Elegir una sola es lo que delata un informe superficial.

SECCIÓN

05

LO QUE VIENE

Bloque 12 · Transición post-cuántica y criptoagilidad

POR QUÉ ESTO NO ES UN TEMA DE CIENCIA FICCIÓN

La pregunta correcta no es cuándo habrá un computador cuántico. Es si el dato que estoy protegiendo hoy seguirá siendo sensible cuando lo haya.

LA CUENTA QUE HAY QUE HACER

vida útil del dato + tiempo que toma migrar > años hasta la amenaza
⇒ ya vamos tarde

Para una hipoteca de Coopaburrá:

vida útil del dato 20 años

tiempo de migración en una entidad .. 3 a 5 años

23 a 25 años

No hay que decidir si la amenaza llega antes de 2050. Hay que decidir
qué se firma hoy sabiendo que debe resistir hasta 2046.

QUÉ SE ROMPE Y QUÉ NO

Es la tabla que más se malinterpreta del tema. No todo cae, y saber distinguir evita gastar donde no hace falta.

MECANISMO	EFFECTO DE UN COMPUTADOR CUÁNTICO	QUÉ HACER
RSA, curvas elípticas, acuerdo de llave	Se rompen por completo. Un algoritmo conocido desde 1994 los resuelve	Migrar a los algoritmos nuevos. Es lo urgente
Cifrado simétrico: AES	Se debilita a la mitad, no se rompe	Usar llaves de 256 bits. Con eso queda resuelto
Funciones resumen	Se debilitan, no se rompen	Preferir salidas de 384 bits en adelante para datos de larga vida
Firmas ya hechas	No se alteran, pero se vuelven falsificables hacia adelante	Resellar con algoritmos nuevos antes de que eso ocurra

LOS ALGORITMOS YA ESTÁN PUBLICADOS

Esto dejó de ser investigación en agosto de 2024. Ya hay normas publicadas y productos que las implementan, así que la pregunta pasó de si migrar a cuándo y en qué orden.

NORMA	QUÉ ESTANDARIZA	PARA QUÉ SE USA
FIPS 203	Encapsulamiento de llave, basado en retículos	Reemplaza el acuerdo de llave: es lo primero que hay que migrar
FIPS 204	Firma digital basada en retículos	La firma de propósito general, para la mayoría de los usos
FIPS 205	Firma digital basada en funciones resumen	Más lenta y más grande, pero su seguridad descansa en supuestos muy conservadores
Algoritmo de respaldo	Un segundo mecanismo de encapsulamiento, de familia matemática distinta	Para no depender de un único supuesto matemático

// EL PLAZO QUE MANEJAN LOS GOBIERNOS

Las guías de transición de los organismos de seguridad nacional apuntan a tener los sistemas críticos migrados hacia 2035, empezando **ahora** por lo que protege datos de larga vida. La cartera hipotecaria de Coopaburrá entra exactamente en esa categoría.

CNSA 2.0: EL CALENDARIO QUE SIGUEN LOS FABRICANTES

La suite de la agencia de seguridad nacional de Estados Unidos no obliga a una cooperativa colombiana, pero es el calendario que siguen los fabricantes, y por eso fija de hecho cuándo llegarán los productos.

TIPO DE SISTEMA	ADMITIR Y PREFERIR	USAR EXCLUSIVAMENTE
Firma de software y de firmware	2025	2030
Equipos de red tradicionales	2026	2030
Navegadores, servidores y servicios en la nube	2025	2033
Sistemas operativos	2027	2033
Aplicaciones a la medida y equipos heredados	—	Actualizar o reemplazar hacia 2033

// LO QUE HAY QUE LEER EN ESTA TABLA

Los cajeros y el hardware de red entran en la ola de 2030. **Un equipo que Coopaburrá compre hoy seguirá en servicio en 2030:** la pregunta de si admite ML-KEM-1024 y ML-DSA-87, los algoritmos de la suite, va en el pliego de esta compra, no de la próxima. La meta general es 2035.

NIST IR 8547: EL FIN ANUNCIADO DE RSA Y LAS CURVAS

El borrador del NIST de noviembre de 2024 pone fecha a lo que la sesión 4 dejó anunciado. Es la referencia que tendrá en la mano un supervisor cuando pregunte por el plan de transición.

HITO	QUÉ SIGNIFICA	PARA COOPABURRÁ
Después de 2030	Se desaprueban RSA y las curvas con seguridad de 112 bits, como RSA-2048	No deben usarse en sistemas nuevos: el certificado RSA-2048 del portal entra aquí
Después de 2035	Se prohíben RSA, Diffie-Hellman y las curvas elípticas, sin importar el tamaño	Ninguna firma de los pagarés debería depender solo de ellos
Mientras tanto	Esquemas híbridos y migración por prioridad de exposición	Primero lo que protege datos de vida larga: las hipotecas

// LA DIFERENCIA ENTRE LAS DOS PALABRAS

Desaprobado significa que se tolera con el riesgo aceptado y documentado; prohibido significa que deja de cumplir. **Entre 2030 y 2035 está la pista de aterrizaje**, y es más corta de lo que parece para una entidad que renueva sistemas cada diez años.

EL TAMAÑO IMPORTA: LAS LLAVES POST-CUÁNTICAS EN CIFRAS

La consecuencia práctica más inmediata de la transición no es de seguridad sino de tamaño. Estos son los números de los estándares, frente a lo que se usa hoy.

ESQUEMA	LLAVE PÚBLICA	CIFRADO O FIRMA	FRENTE A HOY
X25519 · acuerdo clásico	32 bytes	32 bytes	Referencia
ML-KEM-768 · acuerdo post-cuántico	1.184 bytes	1.088 bytes	Unas 37 veces más
Ed25519 · firma clásica	32 bytes	64 bytes	Referencia
ML-DSA-65 · firma post-cuántica	1.952 bytes	3.309 bytes	Unas 50 veces más en la firma
SLH-DSA-128s · firma conservadora	32 bytes	7.856 bytes	Llave mínima, firma enorme

// DÓNDE DUELE

Un certificado con firma post-cuántica ocupa varias veces más, y una cadena completa puede no caber en los primeros paquetes del apretón de manos. **Los cajeros, los lectores de tarjetas y los enlaces lentos son los que más lo van a sentir**, y por eso el inventario tiene que incluir el hardware.

CÓMO SE MIGRA SIN APOSTARLO TODO

// MODO HÍBRIDO

Se combinan el algoritmo clásico y el nuevo, de modo que **haya que romper los dos** para comprometer la comunicación.

Protege contra dos riesgos opuestos: que el clásico caiga por un avance cuántico, y que el nuevo caiga por un fallo de diseño todavía no descubierto.

Es la forma en que se está desplegando hoy en los canales seguros de internet.

// LO QUE CAMBIA EN LA PRÁCTICA

Las llaves y las firmas nuevas son **mucho más grandes**: eso afecta al tamaño de los mensajes, a los certificados y a los dispositivos con memoria limitada.

Los cajeros, los lectores de tarjetas y el hardware embebido son los que más van a sufrir, y son los que más tardan en renovarse.

Por eso el inventario tiene que incluir el hardware, no solo el software.

CRIPTOAGILIDAD: DISEÑAR PARA PODER CAMBIAR

La lección de todo el módulo, convertida en requisito de arquitectura. Ningún algoritmo dura para siempre, así que el sistema tiene que poder cambiarlos sin rehacerse.

PRÁCTICA	QUÉ PERMITE
El algoritmo no está escrito dentro del código, sino en configuración	Cambiarlo sin recompilar ni publicar una versión nueva en la tienda
Cada dato cifrado o firmado lleva anotado con qué se produjo	Convivencia de dos algoritmos durante la transición, y migración gradual
Existe un inventario que dice dónde se usa cada algoritmo	Estimar el alcance de un cambio en horas, no en meses. Es el hallazgo H8 otra vez
Las llaves tienen identificador y versión	Rotar sin ambigüedad y saber qué llave descifra qué
Hay pruebas automatizadas del cambio de algoritmo	Que la migración sea un procedimiento ensayado y no un evento

QUÉ DEBERÍA HACER COOPABURRÁ ESTE AÑO

- 01** **Incluir el algoritmo y el tamaño de llave en el inventario criptográfico**
No es trabajo nuevo: es una columna más en el inventario de la entrega 1. Sin ella no se puede estimar nada.
- 02** **Marcar los datos de vida larga**
Hipotecas, historia de aportes, expedientes laborales. Son los que hay que migrar primero, no los más visibles.
- 03** **Exigir criptoagilidad en las compras y en los contratos con proveedores**
La fábrica de software y el proveedor de cajeros deben comprometerse por escrito a soportar los algoritmos nuevos, con fecha.
- 04** **Usar AES-256 y resúmenes de 384 bits en todo lo nuevo**
Es gratis, es hoy, y quita de la lista de preocupaciones todo el lado simétrico.

EL INVENTARIO CRIPTOGRÁFICO MADURO

Cerramos donde empezamos. Aquel de la entrega 1 era una lista; este es el instrumento de gestión que el módulo completo justifica. Estas son las columnas que debería tener al final.

COLUMNA	PARA QUÉ SIRVE	QUÉ PREGUNTA RESPONDE
Identificador y propósito	Distinguir llaves y evitar reutilización entre usos	¿Cuántas llaves hay y para qué?
Algoritmo y tamaño	Detectar lo que está fuera de política y estimar la migración	¿Qué hay que cambiar antes de 2030?
Dónde reside y bajo qué custodia	Saber el nivel de protección real de cada una	¿Qué pasa si se compromete ese equipo?
Responsable, por rol	Que la salida de una persona no deje llaves huérfanas	¿Quién responde por esta llave hoy?
Fecha de creación y de rotación	Convertir la rotación en una tarea programada	¿Cuáles están vencidas ahora mismo?
Sistemas que dependen de ella	Estimar el impacto de rotarla o retirarla	¿Qué se cae si la cambio?
Vida útil del dato que protege	Priorizar la migración post-cuántica por exposición real	¿Qué hay que migrar primero?

QUÉ SE LE REPORTA AL COMITÉ CADA MES

Un comité no quiere ver hallazgos todos los meses: quiere ver si la situación mejora o empeora. Seis indicadores bastan, y todos salen del inventario.

INDICADOR	POR QUÉ ESE Y NO OTRO
Porcentaje de llaves con responsable nombrado	Es el que más rápido revela el problema de fondo, y el más barato de corregir
Certificados que vencen en los próximos 60 días	Convierte en rutina lo que hoy es una sorpresa cada tanto
Llaves fuera de su periodo de rotación	Si esta cifra no baja, la política existe solo en el papel
Algoritmos en uso fuera de la política vigente	Es el tablero de la migración, incluida la post-cuántica
Llaves encontradas fuera del inventario en el último barrido	Mide si el inventario refleja la realidad o solo la intención
Hallazgos abiertos por antigüedad	Distingue lo que se está resolviendo de lo que solo se está registrando

LO QUE LE EXIGEN A COOPABURRÁ, Y DE DÓNDE SALE

Para la sustentación conviene poder decir de dónde sale cada obligación. Ustedes ya vieron el marco legal conmigo; esto es solo el recorte que aplica a este módulo.

FUENTE	QUÉ EXIGE EN MATERIA CRIPTOGRÁFICA
Ley 527 de 1999	Condiciones para que un mensaje de datos y una firma tengan valor probatorio, y que la información se conserve accesible y consultable con su origen, destino y fecha
Régimen de protección de datos personales	Medidas de seguridad sobre los datos de los 142.000 asociados, y deber de informar incidentes que los afecten
Instrucciones de la Superintendencia Financiera	Requisitos mínimos de seguridad de la información y ciberseguridad para sus vigilados. Citen la circular vigente al momento del informe, no una de memoria
Normas de la industria de medios de pago	Gestión de llaves de los cajeros y protección de datos de tarjeta, con exigencias explícitas de rotación y custodia

SECCIÓN

06

EVALUACIÓN Y CIERRE

Quiz 2, sustentación de la hoja de ruta y cierre del módulo

QUIZ 2 - QUINCE MINUTOS

Cubre las sesiones 4, 5 y 6. Mismo formato del primero: preguntas de criterio, no de memoria. Ninguna pregunta se responde recordando un nombre.

// LO QUE ENTRA

Llave pública y firma digital: qué prueba y qué no.

Certificados: la cadena, las comprobaciones y el ciclo de vida.

Canal seguro: versiones, confidencialidad persistente y límites.

Gestión de llaves: ciclo, ceremonias, jerarquía y rotación.

Conservación y transición post-cuántica.

// CÓMO SE PREGUNTA

Un escenario corto y una decisión que justificar.

Por ejemplo: un proveedor propone algo, ¿qué le preguntan antes de aceptarlo y por qué?

Se evalúa el criterio y la justificación. Una respuesta correcta sin argumento vale la mitad.

LA SUSTENTACIÓN ANTE EL COMITÉ

Setenta minutos. Cada equipo presenta durante diez y responde durante dos. No es una exposición académica: es una reunión de comité, y el auditorio actúa como tal.

01 Se presenta la hoja de ruta, no el diagnóstico

El comité ya conoce los hallazgos. Lo que no sabe es qué hacer primero, con \$180 millones y cuatro horas de ventana semanal.

02 Cada acción va con costo, plazo, responsable y riesgo que mitiga

Una acción sin esas cuatro columnas no se puede aprobar, y por lo tanto no cuenta.

03 El orden hay que defenderlo, no solo enunciarlo

La pregunta que va a llegar siempre es por qué esto antes que aquello. Prepárenla.

04 Y hay que responder la pregunta del apoderado

La misma de la sesión 1: cómo se demuestra que una operación la autorizó su titular. Si al final del módulo no se responde en un minuto, algo falló.

CÓMO SE CALIFICA LA SUSTENTACIÓN

CRITERIO	QUÉ SE MIRA	PESO
Corrección técnica	Que lo afirmado sea cierto y que los mecanismos propuestos resuelvan lo que se dice que resuelven	25%
Priorización justificada	Que el orden responda a exposición y a plazo, no a facilidad. Y que se defienda	25%
Viabilidad	Presupuesto, ventana de mantenimiento, dependencia de proveedores y capacidad del equipo	20%
Defensa ante preguntas	Que se distinga lo que se sabe de lo que se supone, y que se acepte lo que no se sabe	20%
Comunicación al comité	Sin jerga, con cifras y con una recomendación explícita. El comité decide, ustedes recomiendan	10%

LAS SEIS IDEAS QUE DEBERÍAN QUEDAR

LA IDEA

POR QUÉ

El algoritmo casi nunca es el problema

En los ocho hallazgos del caso ninguno era un algoritmo roto: todos eran de uso, de custodia o de gestión

Cada servicio exige un mecanismo distinto

Confidencialidad, integridad, autenticación y no repudio no se resuelven con lo mismo

El no repudio exige una llave privada por persona

Es una decisión de arquitectura, no de configuración, y por eso la toma el comité

La confianza se desplaza, no desaparece

Certificados, entidades acreditadas y sellos de tiempo son formas de repartirla, no de eliminarla

Una llave sin dueño ni fecha es una deuda

Y el inventario es la medida más barata y más rentable de todo el módulo

Nada de esto dura para siempre

Por eso se diseña para poder cambiar. La criptoagilidad es la conclusión, no un tema adicional

LO QUE SE LLEVAN

Este módulo no los convierte en criptógrafos, y ese nunca fue el objetivo. Los convierte en algo que las organizaciones necesitan más y encuentran menos.

// LO QUE NO SABEN HACER, Y ESTÁ BIEN

No saben diseñar un algoritmo, ni implementarlo, ni auditar una biblioteca criptográfica.

Eso es un oficio distinto, con años de formación específica, y la regla profesional es no intentarlo.

// LO QUE SÍ SABEN HACER

Leer una configuración y decir qué protege y qué no.

Distinguir lo que un mecanismo prueba de lo que no prueba, y decirlo delante de un abogado.

Preguntarle a un proveedor lo que hay que preguntarle antes de firmar.

Y priorizar una inversión con criterio y defenderla ante un comité.

Eso es exactamente lo que le faltaba a Coopaburrá en febrero.

TRABAJO INDEPENDIENTE DESPUÉS DE LA SESIÓN 6

12 h

HASTA LA ENTREGA
FINAL, A LOS 8 DÍAS

2 h

LECTURA
DE CIERRE

10 h

VERSIÓN CONSOLIDADA
DEL INFORME

Lectura de cierre · 2 horas

FIPS 203 y FIPS 204

Secciones 1 y 2 de cada una: alcance, conjuntos de parámetros y nivel de seguridad de ML-KEM y ML-DSA. Una hora.

ETSI EN 319 142-1

Firmas PAdES: introducción y niveles B, T, LT y LTA, para precisar la recomendación de H7. Una hora.

La realimentación recibida

Las observaciones de las cinco entregas y de la sustentación: la versión final tiene que responderlas todas.

// ENTREGA FINAL DEL MÓDULO

La versión consolidada del informe se entrega a los ocho días de esta sesión: integra las cinco partes corregidas y la hoja de ruta sustentada. Con estas 12 horas se completan las 64 de trabajo independiente del módulo.

SIGLAS DE LA SESIÓN · 1 DE 2

ACM

Association for Computing Machinery — Asociación profesional que publicó en 1979 el artículo de Shamir sobre el reparto de secretos.

AES / AES-256

Advanced Encryption Standard — Con llaves de 256 bits resiste el cómputo cuántico conocido. Sesión 2.

CNSA 2.0

Commercial National Security Algorithm Suite 2.0 — Suite y calendario post-cuántico de la NSA, publicado en 2022.

ETSI / PAdES

European Telecommunications Standards Institute / PDF Advanced Electronic Signatures — La norma europea de firma avanzada en PDF.

B / T / LT / LTA

Basic, Timestamp, Long-Term, Long-Term with Archive — Los niveles de firma para conservar a largo plazo.

FF1

Modo de cifrado que conserva el formato del dato, de NIST SP 800-38G. Es la base de la tokenización sin bóveda.

FIPS

Federal Information Processing Standards — Normas federales de Estados Unidos; FIPS 140-3 certifica los módulos de hardware.

IETF / RFC / TSP

Internet Engineering Task Force / Request for Comments / Time-Stamp Protocol — El sello de tiempo es el RFC 3161.

ML-KEM / ML-DSA

Module-Lattice-Based Key-Encapsulation Mechanism / Digital Signature Algorithm — Los estándares FIPS 203 y FIPS 204.

NIST / SP / IR

National Institute of Standards and Technology / Special Publication / Interagency Report — El instituto y dos de sus series.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

SIGLAS DE LA SESIÓN · 2 DE 2

NSA

National Security Agency — Agencia de Seguridad Nacional de Estados Unidos; publica la suite CNSA.

PCI DSS / SSC

Payment Card Industry Data Security Standard / Security Standards Council — La norma de la industria de tarjetas y su consejo.

PDF

Portable Document Format — El formato del contrato y del pagaré de las hipotecas de Coopaburrá.

PKI

Public Key Infrastructure — Infraestructura de llave pública. Sesión 5.

RSA / RSA-2048

Rivest, Shamir y Adleman — Llave pública de 1977. RSA-2048 queda desaprobado después de 2030 según NIST IR 8547.

SHA-1

Secure Hash Algorithm 1 — Función resumen rota: el ejemplo de un algoritmo que envejeció con firmas todavía vigentes.

SLH-DSA

Stateless Hash-Based Digital Signature Algorithm — La firma post-cuántica conservadora de FIPS 205.

X25519

Acuerdo de llave sobre la curva 25519: la referencia clásica frente a ML-KEM.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

REFERENCIAS DE LA SESIÓN · 1 DE 2

NIST. (2020).	SP 800-57 Part 1 Rev. 5: Recommendation for key management — Part 1: General.	Estados de la llave y periodos criptográficos
NIST. (2019).	FIPS 140-3: Security requirements for cryptographic modules.	Niveles de los módulos de hardware
NIST. (2024).	FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) y FIPS 205 (SLH-DSA).	Los estándares post-cuánticos
NIST. (2024).	IR 8547, borrador: Transition to post-quantum cryptography standards.	Desaprobación en 2030 y prohibición en 2035
National Security Agency. (2022).	Commercial National Security Algorithm Suite 2.0 (CNSA 2.0).	Algoritmos y calendario por tipo de sistema

REFERENCIAS DE LA SESIÓN · 2 DE 2

NIST. (2016).	SP 800-38G: Methods for format-preserving encryption.	Tokenización sin bóveda: FF1
PCI Security Standards Council. (2011).	Information supplement: PCI DSS tokenization guidelines.	Tokenización y reducción del alcance de auditoría
Shamir, A. (1979).	How to share a secret. Communications of the ACM, 22(11), 612–613.	El reparto de un secreto con umbral
Adams, C. et al. (2001).	RFC 3161: Internet X.509 PKI Time-Stamp Protocol (TSP). IETF.	El sello de tiempo
ETSI. (versión vigente).	EN 319 142-1: PAdES digital signatures — Building blocks and baseline levels.	Niveles B, T, LT y LTA

// ACCESO A LAS FUENTES

Las publicaciones del NIST, de la NSA, del PCI SSC, de la IETF y del ETSI son de acceso libre en sus páginas. El artículo de Shamir se consulta en las bases de datos de la Institución.